Mob psycho

⚠️ **Security Warning**: Work in an isolated environment (virtual machine or container). Never open unknown files on your primary machine.

📋 Challenge Description

Can you handle APKs?

💡 Hints

- Did you know you can unzip APK files?
- Now you have the whole host of shell tools for searching these files.

🧰 Tools Used

- `file` – Determine file type
- `7z` – Extract APK (ZIP archive)
- `ls` – List directory contents
- `cat` – Read file contents
- `xxd` – Convert hexadecimal to text

🔍 Complete Solution

Step 1: Download and Prepare

Download the file named `mobpsycho.apk` from the challenge page.

Step 2: Basic File Inspection

First, verify the file type:

```
file mobpsycho.apk
```

Expected output:

```
mobpsycho.apk: Zip archive data, made by v3.0 UNIX, extract using at least v1.0, last
modified Mar 12 2024 00:06:28, uncompressed size 0, method=store
```

The output confirms this is a **ZIP archive** (APK files are essentially ZIP files).

Step 3: Extract the APK

Since APK files are ZIP archives, we can extract them directly:

```
7z x mobpsycho.apk
```

Output:

```
...
Everything is Ok
```

After extraction, list the contents:

```
ls
```

Output:

```
AndroidManifest.xml  META-INF  classes.dex  classes2.dex  classes3.dex  mobpsycho.apk
res  resources.arsc
```

These are the typical components of an Android APK file:

- `AndroidManifest.xml` – App permissions and configuration
- `classes.dex` – Compiled Java/Kotlin code
- `res/` – Resources (images, layouts, colors, strings)
- `META-INF/` – Signature and metadata

Step 4: Search for the Flag

The flag is likely hidden in the resources. Let's explore the `res` directory:

```
ls res/color
```

Output (excerpt):

```
abc_background_cache_hint_selector_material_dark.xml
abc_background_cache_hint_selector_material_light.xml
...
flag.txt
m3_appbar_overlay_color.xml
...
```

> **Key finding**: A file named **`flag.txt`** in the `res/color` directory! That's suspicious – color resources are usually `.xml` files, not `.txt` .

Step 5: Read the Flag File

```
cat res/color/flag.txt
```

Output:

```
7069636f4354467b6178386d4330525536766 55f4e5838356c346178386d436c5f35653637656135657d
```

The content is a **hexadecimal string**!

Step 6: Decode Hexadecimal to Text

Use `xxd` to convert hex to ASCII:

```
cat res/color/flag.txt | xxd -r -p
```

Output:

```
picoCTF{<REDACTED>}
```

Step 7: Alternative – Decode with Python

```python
hex_string = "7069636f4354467b6178386d433052553676655f4e5838356c346178386d436c5f35653637656135657d"
flag = bytes.fromhex(hex_string).decode()
print(flag)
```

Output:

```
picoCTF{<REDACTED>}
```

Step 8: Alternative – Decode with CyberChef

1. Go to https://gchq.github.io/CyberChef/
2. Paste the hex string: `7069636f4354467b6178386d433052553676655f4e5838356c346178386d436c5f35653637656135657d`
3. Add the "From Hex" operation
4. The flag appears instantly

✅ Final Result

```
picoCTF{<REDACTED>}
```

> **Note**: The actual flag is redacted here. In the real challenge, decoding the hex string will reveal the complete flag.

🧠 Key Concepts

Concept	Description
APK (Android Package Kit)	The file format for Android applications – actually a ZIP archive.
APK Structure	Contains `classes.dex` (code), `AndroidManifest.xml` (config), and `res/` (resources).
res/color/	Directory for color resources (normally `.xml` files).
Hexadecimal Encoding	Representing text as pairs of hex digits (e.g., `70` = ‘p’, `69` = ‘i’).
xxd -r -p	Reverse hexdump – converts hex back to raw text.

💡 Pro Tips

1. **APK files are just ZIP files** – You can extract them with any tool that handles ZIP archives (`unzip` , `7z` , `jar xf`).
2. **Look for suspicious file names** – A file named `flag.txt` in a directory that should only contain `.xml` files is a big red flag.
3. **Hex strings often start with `70`** – `70 69 63 6f` = “pico”. Recognizing this pattern helps identify hex-encoded flags quickly.
4. **Use `strings` on unknown files** – Even if you don’t know where the flag is, `strings` might reveal it.
5. **Check all resource directories** – Flags can be hidden in `res/values` , `res/raw` , `res/drawable` , or `res/color` .
6. **`xxd -r -p` is your friend** – This command converts hex strings back to readable text.

🔗 Alternative Hex Decoding Tools

Tool	Command / Link
Linux `xxd`	`echo "hex" | xxd -r -p`

Tool	Command / Link
Python	`bytes.fromhex(hex).decode()`
CyberChef	https://gchq.github.io/CyberChef/ (Operation: From Hex)
Online	https://www.rapidtables.com/convert/number/hex-to-ascii.html